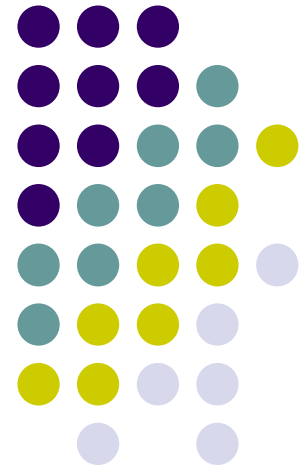
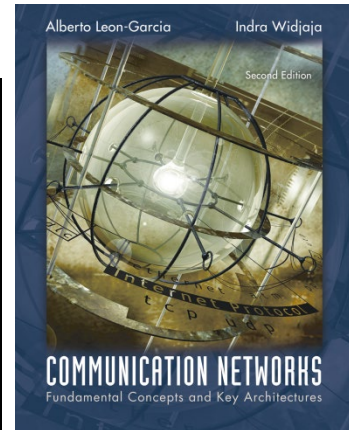


Lecture 4 (Chapter 11)

Security Protocols

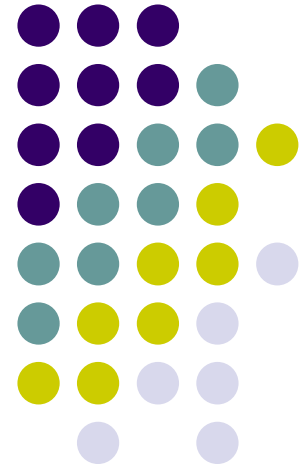
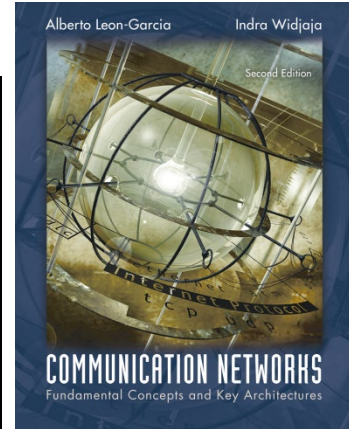
Network Security Threats
Security and Cryptography
Network Security Protocols
Cryptographic Algorithms



Chapter 11

Security Protocols

Network Security Threats



Network Security



- The combination of low-cost powerful computing and high-performance networks is a two-edged sword:
 - Many powerful new services and applications are enabled
 - But computer systems and networks become highly susceptible to a wide variety of security threats
- Network security involves countermeasures to protect computer systems from intruders
 - Firewalls, security protocols, security practices
 - We will focus on security protocols

Threats, Security Requirements, and Countermeasures



- Network Security Threats
 - Eavesdropping, man-in-the-middle, client and server imposters
 - Denial of Service attacks
 - Viruses, worms, and other malicious code
- Network Security Requirements
 - Privacy, Integrity, Authentication, Non-Repudiation, Availability
- Countermeasures
 - Communication channel security
 - Border security

Security Requirements



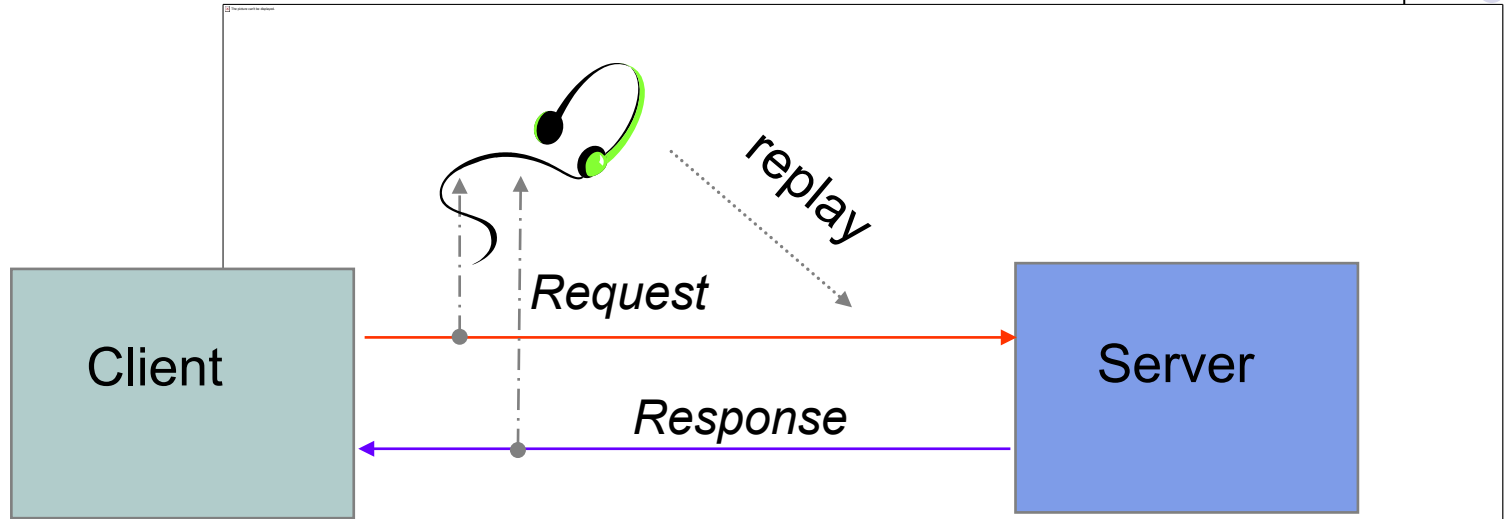
Security threats motivate the following requirements:

- *Privacy*: information should be readable only by intended recipient
- *Integrity*: recipient can confirm that a message has not been altered during transmission
- *Authentication*: it is possible to verify that sender or receiver is who he claims to be
- *Non-repudiation*: sender cannot deny having sent a given message.
- *Availability*: of information and services

Types of Security Threats

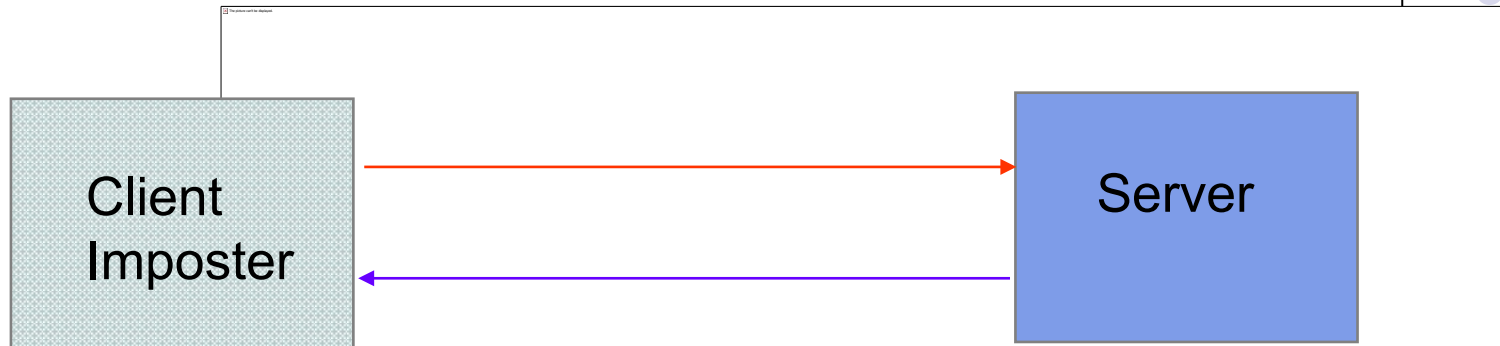


Eavesdropping



- Information transmitted over network can be observed and recorded by eavesdroppers (using a packet sniffer)
- Information can be replayed in attempts to access server
- Requirements: privacy, authentication, non-repudiation

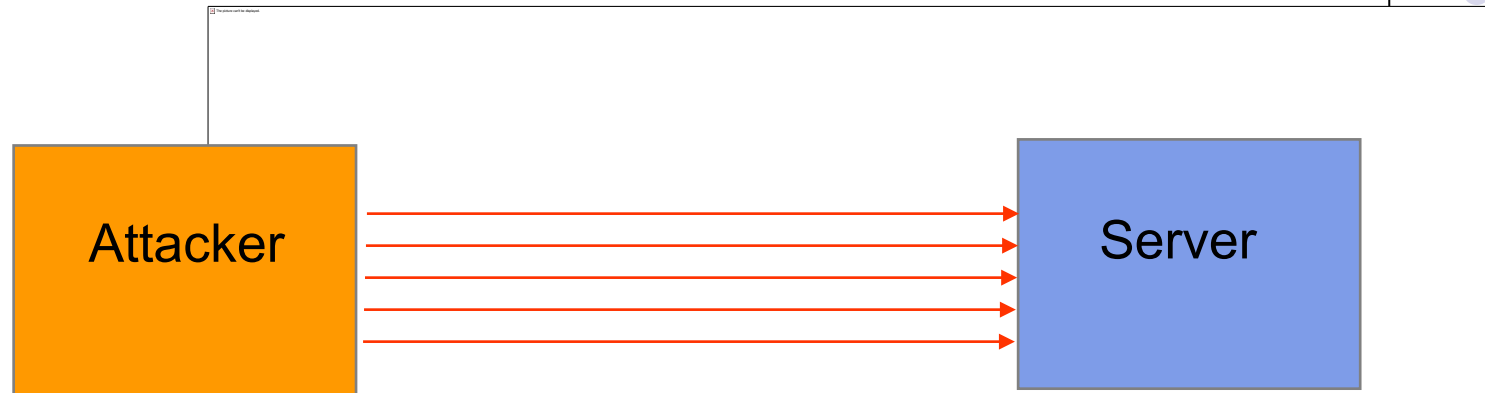
Client Imposter



- Imposters attempt to gain unauthorized access to server
 - Ex. bank account or database of personal records
 - For example, in IP spoofing imposter sends packets with false source IP address
- Requirements: privacy, authentication

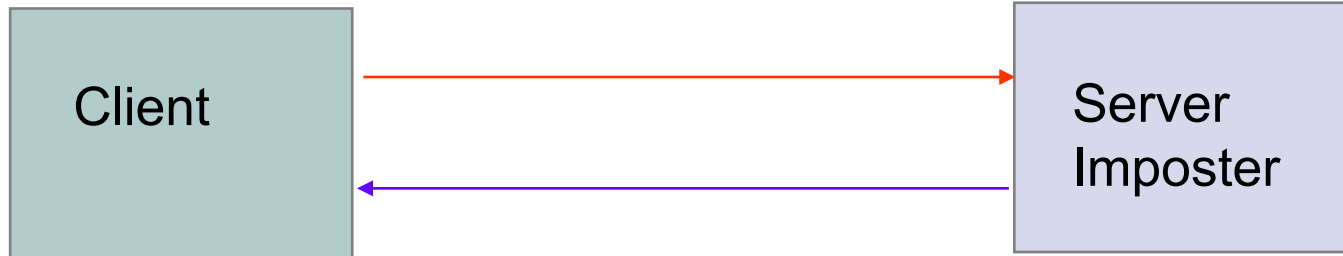


Denial of Service Attack



- Attacker can flood a server with requests, overloading the server resources
 - Results in *denial of service* to legitimate clients
- Distributed denial of service attack on a server involves coordinated attack from multiple (usually hijacked) computers
- Requirement: availability

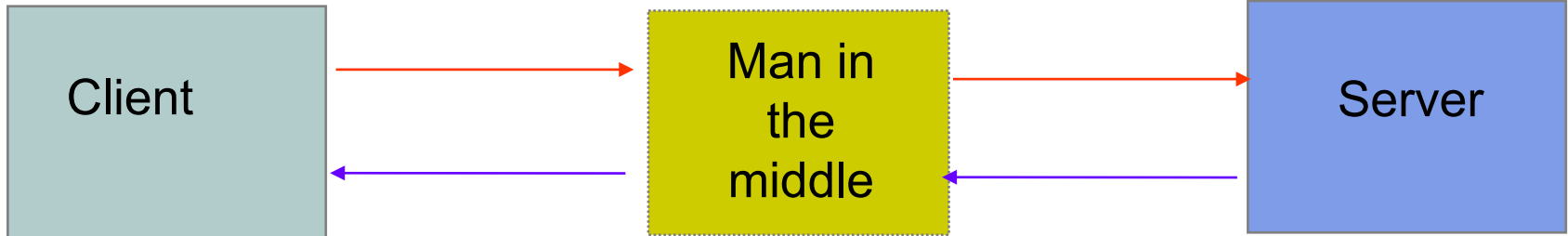
Server Imposter



- An imposter impersonates a legitimate server to gain sensitive information from a client
 - E.g. bank account number and associated user password
- Requirements: privacy, authentication, non-repudiation



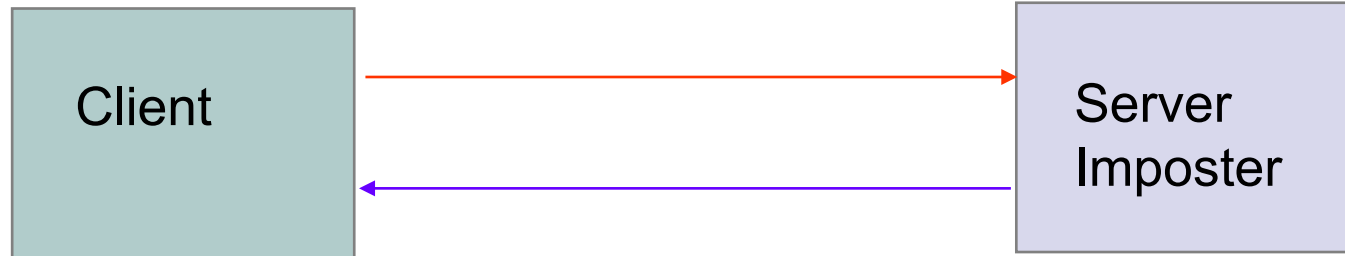
Man-in-the-Middle Attack



- An imposter manages to place itself as *man in the middle*
 - convincing the server that it is legitimate client
 - convincing legitimate client that it is legitimate server
 - gathering sensitive information and possibly hijacking session
- Requirements: integrity, authentication



Malicious Code



- A client becomes infected with malicious code
 - Opening attachments in email messages
 - Executing code from bulletin boards or other sources
- Virus: code that, when executed, inserts itself in other programs
- Worms: code that installs copies of itself in other machines attached to a network
- Many variations of malicious code
- Requirements: privacy, integrity, availability

Countermeasures



- *Secure communication channels*
- Encryption
- Cryptographic checksums and hashes
- Authentication
- Digital Signatures

Countermeasures

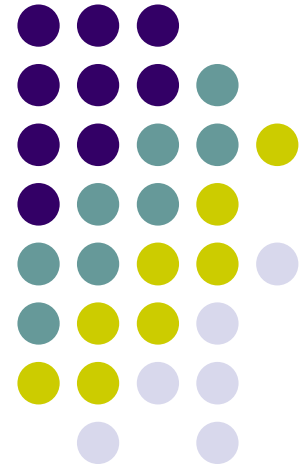
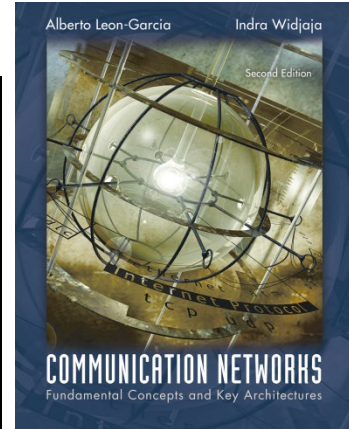


- *Secure borders*
- Firewalls
- Virus checking
- Intrusion detection
- Authentication
- Access Control

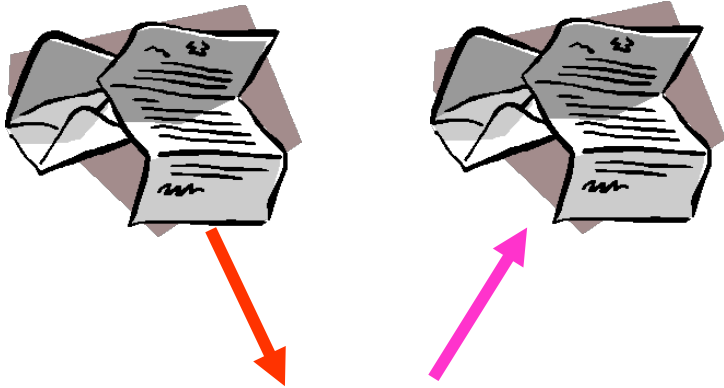
Chapter 11

Security Protocols

Security and Cryptography



Cryptography



- *Encryption*: transformation of *plaintext* message into encrypted (and unreadable) message called *ciphertext*
- *Decryption*: recovery of plaintext from ciphertext
- *Cipher*: algorithm for encryption & decryption
- A *secret key* is required to perform encryption & decryption

Substitution Ciphers



Substitution Cipher: Map each letter or numeral into another letter or numeral:

a b c d e f g h i j k l m n o p q r s t u v w x y z

z y x w v u t s r q p o n m l k j i h g f e d c b a

- Example:
 - hvxfirgb → security
- Substitution ciphers are easy to break
 - Take histogram of frequency of occurrence of letters in a ciphertext message
 - Match to known frequencies of letters

Other Substitution Cipher (Vigenere Cipher)



- In a monoalphabetic cipher, the same substitution rule is used at every character position in the plaintext message. In a **poly-alphabetic cipher**, on the other hand, the substitution rule changes continuously from one character position to the next in the plain-text according to the elements of the encryption key.
- “align” the encryption key with the plaintext message. [If the plaintext message is longer than the encryption key, you can repeat the encryption key, as we show below where the encryption key is “abracadabra”.]



- Now consider each letter of the encryption key denoting a Vigenere cipher, the shift corresponding to the letter of the key. This is illustrated with the help of the table shown on the next page.
- Example:

key: abracadabraabracadabraabracadabraab

plaintext: canyoumeetmeatmidnightihavethegoods

ciphertext: CBEYQUPEFKMEBK.....

Vigenere Cipher Table



	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y

Transposition Cipher



Transposition Cipher: Rearrange order of letters/numerals in a message using a particular rearrangement:

- interchange character k with character $k+1$
- Example:
 - security $\rightarrow$ esuciryt
- Transposition Ciphers are easy to break
 - Suppose plaintext and ciphertext are known
 - Matching of letters in plaintext and ciphertext will reveal transposition mapping



Columnar Transposition example,

Key: 4 3 1 2 5 6 7

Plaintext: a t t a c k p
o s t p o n e
d u n t l l t
w o a m x y z

Ciphertext: TTNAAPTMTSUOAODWCOIXKNLYPETZ

Thus, in this example, the key is 4312567. To encrypt, start with the column that is labeled 1, in this case column 3. Write down all the letters in that column. Proceed to column 4, which is labeled 2, then column 2, then column 1, then columns 5, 6, and 7.

A pure transposition cipher is easily recognized because it has the same letter frequencies as the original plaintext. For the type of columnar transposition just shown, cryptanalysis is fairly straightforward and involves laying out the ciphertext in a matrix and playing around with column positions.

The transposition cipher can be made significantly more secure by performing more than one stage of transposition. The result is a more complex permutation that is not easily reconstructed. Thus, if the foregoing message is reencrypted using the same algorithm,

Key: 4 3 1 2 5 6 7

**Input: t t n a a p t
m t s u o a o
d w c o i x k
n l y p e t z**

Output: NSCYAUOPTTWLTMDNAOIEPAXTTOKZ



Example:



To visualize the result of this double transposition by using the same key as example above, designate the letters in the original plaintext message by the numbers designating their position. Thus, with 28 letters in the message, the original sequence of letters is

01 02 03 04 05 06 07 08 09 10 11 12 13 14
15 16 17 18 19 20 21 22 23 24 25 26 27 28

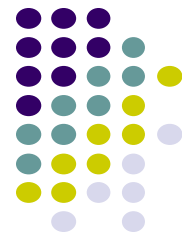
1st

03 10 17 24 04 11 18 25 02 09 16 23 01 08
15 22 05 12 19 26 06 13 20 27 07 14 21 28

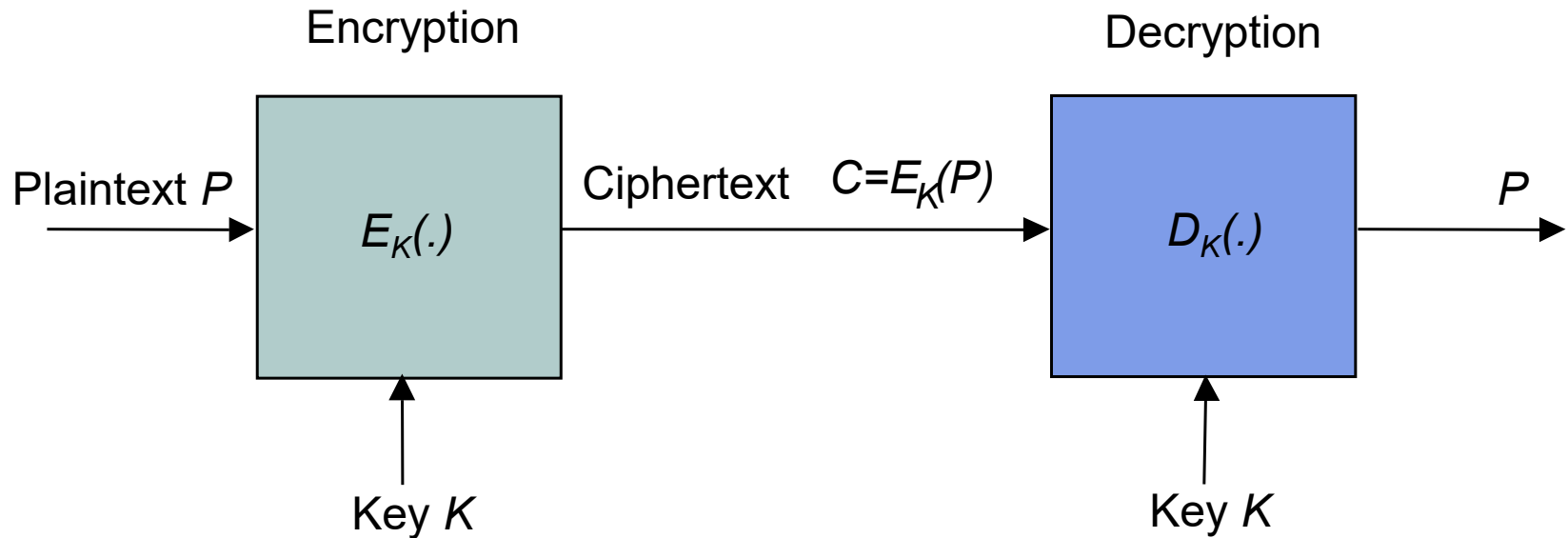
2nd

17 09 05 27 24 16 12 07 10 02 22 20 03 25
15 13 04 23 19 14 11 01 26 21 18 08 06 28

*add more



Secret Key Cryptography/ Symmetric Key Cryptography



- Sender encrypts P by applying mapping E_K which depends on *secret key* K : $C = E_K(P)$
- Receiver decrypts C by applying inverse mapping D_K which also depends on K : $D_K(E_K(P)) = P$

What makes a good cipher?



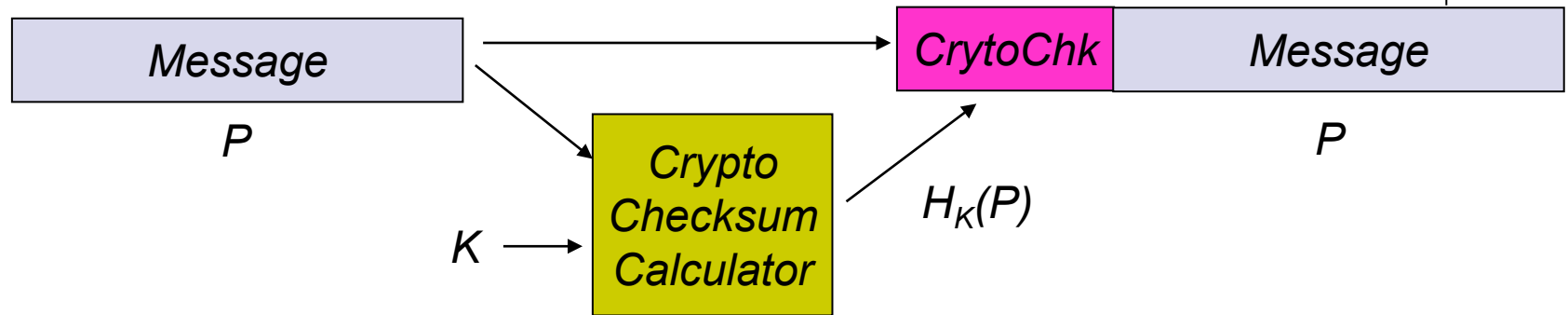
- Algorithm should be easy to implement and deploy on large scale
- Algorithm should be difficult to break:
 1. Number of keys should be very large
 - Attacker cannot try all possible keys
 2. The secret key should be very hard to derive from intercepted messages
 - Even if a large number of plaintext & corresponding cyphertexts are known to the attacker
- Examples of secret key methods discussed later:
 - Data Encryption Standard (DES) and Triple DES
 - Advanced Encryption Standard (AES)

Security using Secret Key Cryptography



- *Privacy*: secret key provides messages confidential
- *Integrity*: alteration of the cyphertext will be detected, because the decrypted message will be gibberish
 - When privacy is not required, encryption of the entire message is overkill because much processing involved
 - We will see that cryptographic checksums provide integrity and require less processing

Cryptographic Checksums and Hashes



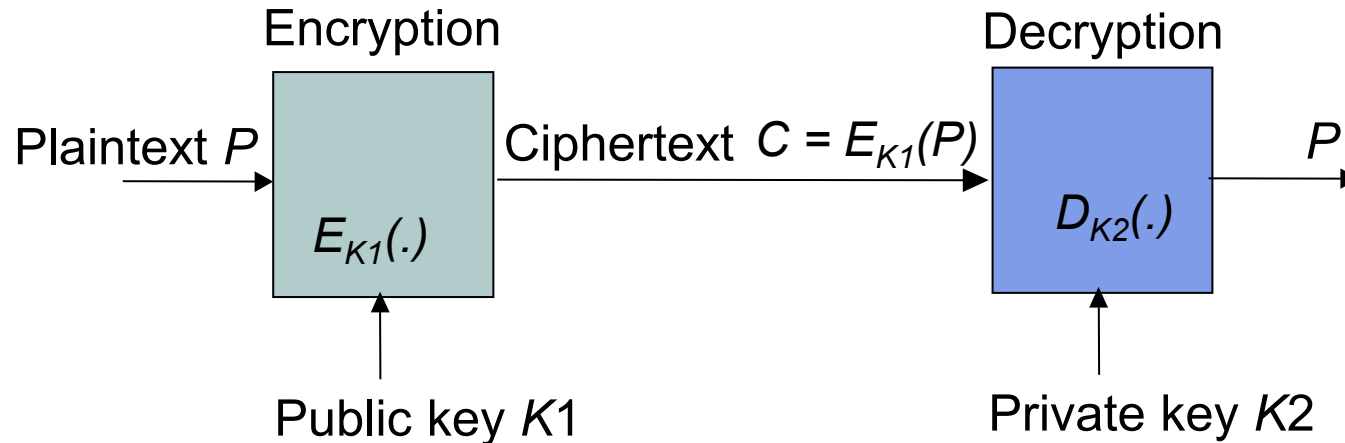
- Transmitter calculates a fixed number of bits (crypto checksum/hash) that depends on secret key K : $H_K(P)$
- Receiver recalculates hash from received message & compares to received hash

Some Hashing Algorithms

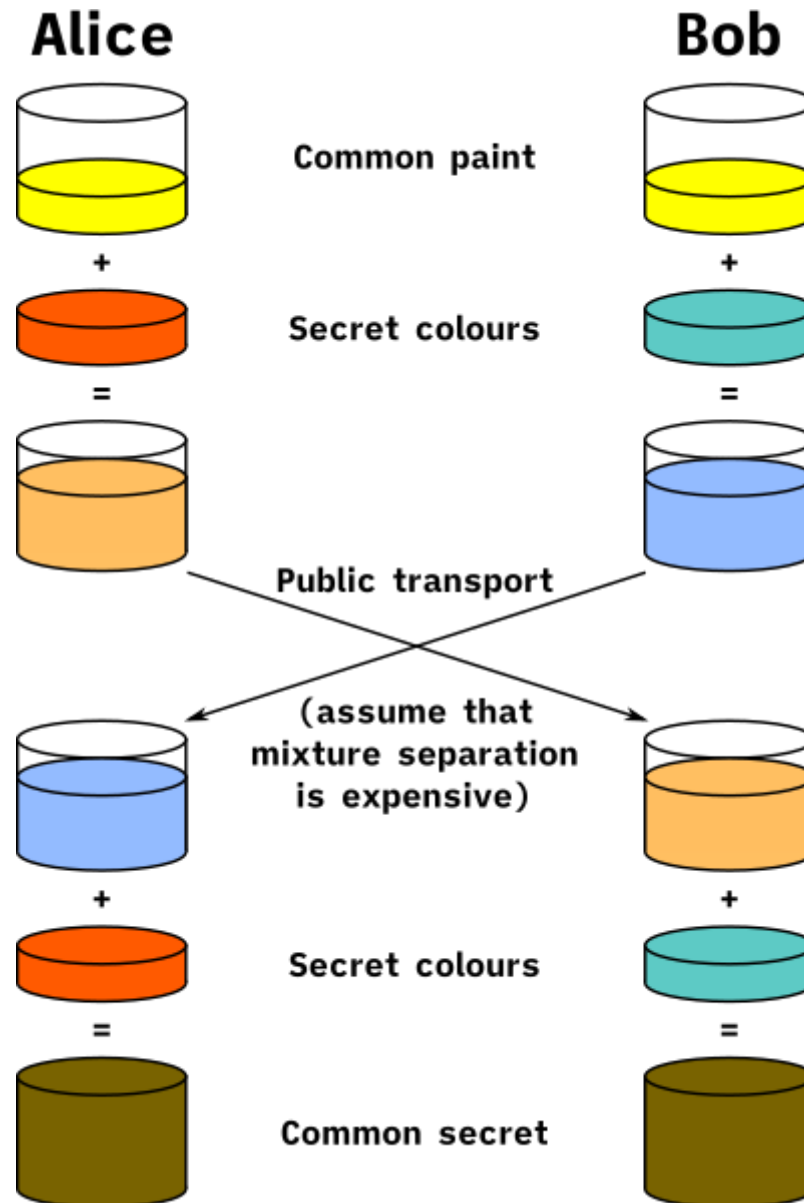


- Message Digest 5 (MD5)
 - Pad message to be multiple of 512 bits
 - Initialize 128 buffer to given value
 - Modify buffer content according to next 512 bits
 - Repeat until all blocks done
 - Buffer holds 128 bit hash
- Keyed MD5
 - Pad message to be multiple of 512 bits
 - Attach and append secret key to padded message prior to performing hash function
 - Could also append/attach other information such as sender ID
- Secure Hash Algorithm 1 (SHA-1)
 - Produce a 160-bit hash; more secure than MD5
 - Keyed version available

Public Key Cryptography/Assymmetric Cryptography



- *Public key cryptography provides privacy* using two different keys:
 - *Public key $K1$* available to all for encrypting messages to a certain user: $C = E_{K1}(P)$
 - *Private key $K2$* for user to decrypt messages: $P = D_{K2}(E_{K1}(P))$



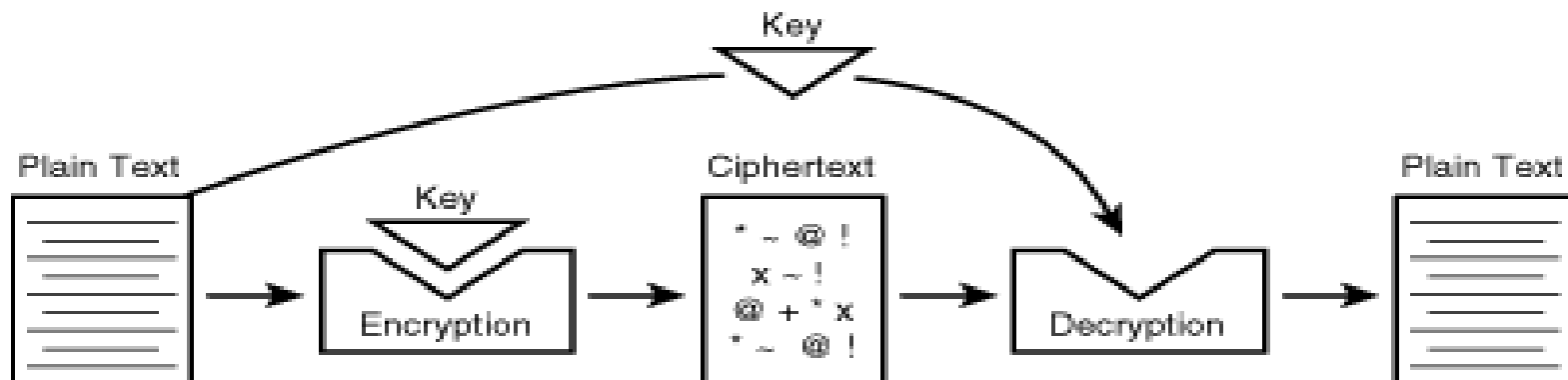
Secret Key vs. Public Key



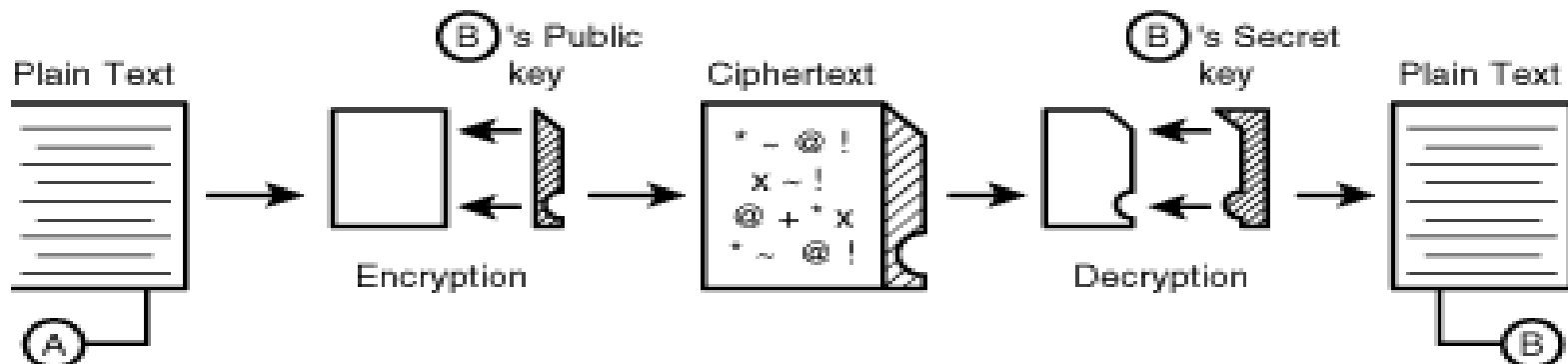
- Public key systems have more capabilities
 - Secret key: privacy, integrity, authentication
 - Public key: all of above + digital signature
- Public key algorithms are more complex
 - Require more processing and hence much slower than secret key
- Practice:
 - Use public key method during session setup to establish a *session key*
 - Use secret key cryptography during session using the session key



Private Key Encryption



Public Key Encryption



Example: Pretty Good Privacy (PGP)



- PGP developed by Phillip Zimmerman to provide secure email
 - <http://www.philzimmermann.com/index.shtml>
 - <http://www.pgpi.org>
- Notorious for becoming publicly available for download over Internet in violation of US export restrictions
- Uses public key cryptography to provide
 - Privacy, integrity, authentication, digital signature
- De facto standard for email security
- Also provides privacy and integrity for stored files

PGP Encrypt & Decrypt

